

VirtuEx 시스템 감사 보고서 (10차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 10차 감사 (소셜/커뮤니티 기능 + UX 개선 감사) 작성일: 2026-03-09 작성: 시스템 감사팀

1. 개요

10차 감사는 VirtuEx 프로젝트의 **소셜/커뮤니티 기능 확장** 및 **UX 개선**을 중심으로 한 정기 감사입니다. 9차 감사(2026-03-07) 이후 구현된 팔로우, 활동 피드, 카피 트레이딩, 실시간 알림 등 신규 소셜 기능과 관련 버그 수정, 데이터베이스 변경, i18n 확장, 코드 품질 개선 사항을 검증합니다.

1.1 감사 범위

영역	검사 항목	신규 이슈
신규 기능 — 팔로우/활동 피드	TraderFollow, TraderActivity 모델, API, UI	5건
신규 기능 — 카피 트레이딩	CopyTradeConfig, CopyTradeExecution, 스케일 비율, 손절	6건
신규 기능 — 커뮤니티 확장	공개/멤버 전용 게시글, 전략 작성 제한	3건
신규 기능 — 실시간 알림	NotificationBell 헤더 통합, 로그인 필수 모달	2건
버그 수정 검증	followingData.map 오류, HelpCircle 미사용 import 등	—
데이터베이스 변경	4개 신규 테이블, visibility 컬럼	4건
i18n	49개 신규 번역 키	2건
UX/접근성	부드러운 사용자 경험, 비인증 사용자 동선	5건
코드 품질	이중 언어 주석, 타입 안정성, 에러 처리	3건
합계		30건

1.2 심각도 분류

심각도	건수
상 (Critical)	3
중 (Medium)	17
하 (Low)	10
합계	30

2. 9차 감사 수정 현황

9차 감사에서 발견된 48건의 수정 현황을 검증합니다.

2.1 수정 완료 (48건)

9차 감사에서 발견된 48건 전량이 `fix: 9차 감사 48건 수정 커밋(950d3cd)`에서 수정 완료되었습니다.

9차 #	항목	수정 내용
#1	XSS: 커뮤니티 HTML 미살균 렌더링	DOMPurify 적용
#2	채팅 markRead useEffect 무한 재실행	ref 기반 의존성 정리
#3	Redis 헬스체크 비밀번호 누락	-a 옵션 추가
#4	CI Dockerfile 경로 오류	서비스별 경로로 수정
#5-#48	프론트엔드 보안/코드 품질/접근성/i18n/성능/인프라	전량 수정 완료

9차 감사 48건 수정률: **100%** (역대 최고)

3. 상 (Critical) — 3건

#1. 카피 트레이딩 스케일 비율 입력값 범위 미검증

- 심각도: 상
- 영역: 백엔드 보안 — 카피 트레이딩
- 파일: backend/services/portfolio/src/copy-trade/ (CopyTradeConfig 관련)
- 설명: CopyTradeConfig의 scaleRatio 필드에 대한 서버 측 범위 검증이 부재합니다. 사용자가 극단적 비율(예: 100x, 0x, 음수)을 설정할 경우 카피 트레이딩 실행 시 비정상적 주문 금액이 발생할 수 있습니다. 프론트엔드 UI에서 제한 하더라도 API 직접 호출로 우회 가능합니다.
- 권장 수정: DTO에 @Min(0.01) @Max(10) 등 합리적 범위 제한 데코레이터 추가.
maxInvestmentPerTrade 필드도 동일하게 @Min(1) 검증 필요

#2. 카피 트레이딩 동시 실행 시 잔고 경합 조건

- 심각도: 상
- 영역: 데이터 무결성 — 카피 트레이딩
- 파일: backend/services/portfolio/ (CopyTradeExecution 관련)
- 설명: 팔로우 중인 트레이더가 동시에 여러 거래를 체결하면, 카피 트레이딩이 병렬로 주문을 생성합니다. 이 때 잔고 확인 과 차감 사이에 경합 조건(race condition)이 발생하여 가용 잔고를 초과하는 주문이 체결될 수 있습니다.
- 권장 수정: CopyTradeExecution 생성 시 \$transaction + FOR UPDATE 락을 사용하여 잔고의 원자적 확인/ 차감 보장. maxInvestmentPerTrade 와 별도로 카피 트레이딩 전체 일일 한도 설정 권장

#3. 팔로우 API 응답 형식 불일치 (수정 완료 검증)

- 심각도: 상 → 수정 완료
- 영역: 백엔드/프론트엔드 연동
- 파일: 팔로우 API 엔드포인트, 프론트엔드 팔로우 훅
- 설명: followingData.map is not a function 에러가 발생했던 건입니다. API가 배열이 아닌 객체({ data: [...], total: N })를 반환하는데, 프론트엔드에서 응답을 직접 .map() 으로 순회하여 TypeError가 발생했습니다.
- 수정 확인: API 응답에서 data 프로퍼티를 추출하거나, 응답 형식이 배열인지 확인 후 처리하도록 수정 완료

4. 중 (Medium) — 17건

4.1 카피 트레이딩 (6건)

#	항목	설명
#4	CopyTradeConfig 손절(stopLoss) 퍼센트 검증 누락	stopLossPercent에 @Min(0) @Max(100) 미적용. 100% 초과 값 허용 가능
#5	카피 실행 실패 시 재시도/알림 로직 부재	원본 트레이더 거래 카피 실패 시 사용자에게 알림 없이 무시됨
#6	카피 트레이딩 비활성화 시 미체결 카피 주문 처리 미정의	카피 설정 비활성화 후에도 이미 생성된 미체결 주문 유지. 일괄 취소 옵션 필요
#7	CopyTradeExecution 테이블 원본 주문 참조 무결성	원본 트레이더 주문 삭제/취소 시 카피 실행 레코드의 참조 정합성 미보장
#8	카피 트레이딩 슬리피지(slippage) 보호 미구현	원본 거래와 카피 거래 사이 시간차로 인한 가격 괴리 보호 없음
#9	카피 트레이더 수 제한 미적용	한 사용자가 무제한 트레이더를 카피 가능. 서버 리소스/잔고 분산 이슈

4.2 팔로우/활동 피드 (4건)

#	항목	설명
#10	TraderActivity 피드 페이지네이션 무한 스크롤 시 전체 로드	팔로우 트레이더가 많을 경우 활동 피드 쿼리가 N+1 문제 발생 가능
#11	팔로우 수 카운트 실시간 불일치	팔로우/언팔로우 시 프로필의 팔로워 수가 캐시로 인해 즉시 반영되지 않음
#12	자기 자신 팔로우 방지 서버 검증	프론트엔드에서 UI 숨김 처리하지만 API 레벨 검증 필요
#13	TraderActivity 민감 정보 노출	활동 피드에 거래 금액/수량이 그대로 노출. 비율 기반 표시로 변환 권장

4.3 커뮤니티 확장 (3건)

#	항목	설명
#14	community_posts visibility 컬럼 기본값 미설정	기존 게시글에 대한 마이그레이션 기본값 확인 필요. NULL 허용 시 필터링 로직 오류 가능
#15	전략 작성 제한(5% 수익률 or 상위 20%) 우회 가능	조건 확인이 프론트엔드 또는 API 호출 시점에만 수행되고, 게시글 작성 API에서 재검증하지 않을 경우 직접 API 호출로 우회 가능
#16	MEMBERS_ONLY 게시글 비인증 사용자 접근 시 에러 처리 미흡	로그인 필수 모달이 있으나, 직접 URL 접근 시 에러 대신 빈 페이지 표시 가능

4.4 UX/접근성 (4건)

#	항목	설명
#17	NotificationBell 실시간 갱신 주기 최적화	폴링 방식 사용 시 불필요한 요청 발생. WebSocket 기반 푸시로 전환 권장

#18	로그인 필수 모달 접근성 (포커스 트랩)	로그인 필수 모달이 <code>role="dialog", aria-modal</code> , 포커스 트랩 구현 여부 확인 필요
#19	카피 트레이딩 설정 UI 복잡도	스케일 비율, 최대 투자금, 손절 퍼센트 등 다수 옵션. 초보 사용자를 위한 프리셋(보수적/적극적) 제공 권장
#20	활동 피드 빈 상태 UX	팔로우 트레이더가 없거나 활동이 없을 때 적절한 안내 메시지 및 트레이더 추천 필요

5. 하 (Low) — 10건

#	영역	항목	설명
#21	코드 품질	HelpCircle 미사용 import 제거 (수정 완료)	BottomNav.tsx에서 사용되지 않는 HelpCircle import 제거 확인
#22	코드 품질	카피 트레이딩 관련 콘솔 로그 잔존 가능성	개발 중 디버깅용 <code>console.log</code> 가 남아있을 수 있음
#23	i18n	카피 트레이딩 UI 텍스트 일부 t() 미적용	49개 키 추가되었으나, 에러 메시지/툴팁 등 일부 누락 가능
#24	i18n	활동 피드 시간 표시 로케일 미적용	"2 hours ago" 등 상대 시간 표시가 영어 고정일 수 있음
#25	DB	trader_follows 테이블 복합 유니크 인덱스 확인	(followerId, followingId) 복합 유니크 제약 없을 경우 중복 팔로우 가능
#26	DB	trader_activities 테이블 보존 정책 미설정	거래 활동 로그 무한 증가. 90일 이상 데이터 아카이빙/삭제 정책 필요
#27	DB	copy_trade_executions 테이블 인덱스 최적화	userId + createdAt 복합 인덱스 없을 경우 실행 이력 조회 시 풀 스캔
#28	UX	팔로우 버튼 옵티미스틱 UI 미적용	팔로우/언팔로우 클릭 시 서버 응답 대기 동안 지연 체감
#29	UX	카피 트레이딩 실행 이력 정렬/필터 미구현	종목별, 수익/손실별, 기간별 필터링 기능 부재
#30	성능	활동 피드 무한 스크롤 메모리 누수 가능	오래된 피드 항목이 DOM에 계속 유지. 가상 스크롤 (virtualization) 미적용

6. 신규 기능 구현 검증

6.1 팔로우 시스템 (TraderFollow)

항목	상태	비고
TraderFollow 모델 (user-auth)	✅ 구현	trader_follows 테이블 생성
팔로우/언팔로우 API	✅ 구현	실시간 팔로우 상태 토글
팔로워/팔로잉 수 조회	✅ 구현	프로필 페이지 연동

API 응답 형식 정합성	✅ 수정 완료	followingData.map 에러 해결
---------------	---------	-------------------------

6.2 활동 피드 (TraderActivity)

항목	상태	비고
TraderActivity 모델 (portfolio)	✅ 구현	trader_activities 테이블 생성
팔로우 트레이더 거래 피드	✅ 구현	실시간 거래 내역 표시
피드 페이지네이션	⚠️ 부분	대량 데이터 시 N+1 쿼리 우려 (#10)

6.3 카피 트레이딩

항목	상태	비고
CopyTradeConfig 모델	✅ 구현	스케일 비율, 최대 투자금, 손절 설정
CopyTradeExecution 모델	✅ 구현	카피 거래 실행 기록
설정 생성/수정/비활성화 API	✅ 구현	—
자동 카피 실행 로직	⚠️ 부분	경합 조건 미해결 (#2), 슬리피지 미보호 (#8)

6.4 커뮤니티 확장

항목	상태	비고
visibility 컬럼 (PUBLIC/MEMBERS_ONLY)	✅ 구현	community_posts 테이블
전략 작성 제한	✅ 구현	5% 수익률 or 상위 20% 자산
AuthGuard 제거 (공개 접근)	✅ 수정 완료	비인증 사용자 게시판 열람 가능
로그인 필수 모달	✅ 구현	비인증 사용자 글쓰기/댓글 시 표시

6.5 실시간 알림

항목	상태	비고
NotificationBell 헤더 통합	✅ 구현	전역 알림 아이콘
알림 बै지 실시간 갱신	⚠️ 부분	WebSocket 기반 추천 (#17)

7. 데이터베이스 변경 검증

7.1 신규 테이블 (4개)

테이블	서비스	주요 컬럼	이슈
trader_follows	user-auth	followerId, followingId, createdAt	복합 유니크 인덱스 확인 필요 (#25)

trader_activities	portfolio	userId, type, symbol, quantity, price, createdAt	보존 정책 미설정 (#26)
copy_trade_configs	portfolio	userId, targetUserId, scaleRatio, maxInvestmentPerTrade, stopLossPercent, isActive	입력값 범위 검증 누락 (#1)
copy_trade_executions	portfolio	configId, originalOrderId, copiedOrderId, status, createdAt	인덱스 최적화 필요 (#27)

7.2 스키마 변경 (1건)

테이블	변경	이슈
community_posts	visibility 컬럼 추가 (PUBLIC/MEMBERS_ONLY)	기본값/마이그레이션 확인 필요 (#14)

8. i18n 확장 검증

- 49개 신규 번역 키 추가 (한국어/영어 이중 언어)
- 대상 영역: 팔로우 UI, 활동 피드, 카피 트레이딩 설정, 커뮤니티 공개 설정, 로그인 필수 모달
- 잔존 이슈: 에러 메시지 일부 및 상대 시간 표시 로케일 미적용 (#23, #24)

9. 수정 완료 사항

본 감사 기간 중 수정이 확인된 버그/이슈:

항목	원인	수정 내용
followingData.map is not a function	API 응답이 배열이 아닌 페이지네이션 객체 반환	응답에서 data 프로퍼티 추출 또는 형식 검증 후 처리
HelpCircle 미사용 import	BottomNav.tsx에서 더 이상 사용하지 않는 아이콘 import 잔존	import 문 제거
리더보드 비시스템 사용자 미갱신	리더보드 데이터 쿼리에서 시스템 사용자만 업데이트	전체 사용자 대상으로 쿼리 수정
커뮤니티 AuthGuard 공개 접근 차단	게시판 열람에 인증 필수 적용	AuthGuard 제거, 글쓰기/댓글만 인증 필요

10. 긍정적 평가 사항

9차 감사 이후 확인된 개선 사항 및 우수한 구현:

- 소셜 기능 아키텍처: 팔로우, 활동 피드, 카피 트레이딩이 기존 마이크로서비스 구조(user-auth, portfolio)에 자연스럽게 통합
- 카피 트레이딩 설계: 스케일 비율, 최대 투자금, 손절 3단계 안전장치 설계
- 커뮤니티 접근 정책: 비인증 사용자도 게시판 열람 가능하도록 개선. 로그인 필수 모달로 부드러운 전환 유도
- 전략 작성 자격 제한: 실적 기반(5% 수익률 or 상위 20%) 게이팅으로 콘텐츠 품질 보장
- 이중 언어 주석: 모든 신규 코드에 한/영 이중 주석 적용 (JSDoc 멀티라인)

- 9차 감사 48건 전량 수정: 역대 최고 수정률 100% 달성
- 코드 전반 주석 표준화: docs: 코드 전반 한/영 이중 주석 추가 커밋으로 기존 코드까지 주석 정비

11. 최우선 조치 권장 순서

순위	#	항목	이유
1	#1	카피 트레이딩 scaleRatio 범위 검증	극단적 값으로 비정상 주문 생성 가능
2	#2	카피 트레이딩 잔고 경합 조건	동시 카피 실행 시 잔고 초과 주문 위험
3	#12	자기 자신 팔로우 서버 검증	API 직접 호출로 우회 가능
4	#15	전략 작성 제한 서버 재검증	자격 미달 사용자 전략 게시 가능
5	#8	카피 트레이딩 슬리피지 보호	가격 괴리로 인한 예기치 않은 손실
6	#25	trader_follows 복합 유니크 인덱스	중복 팔로우 데이터 방지
7	#14	visibility 컬럼 기본값	기존 게시글 필터링 오류 방지

12. 이전 감사 대비 추이

차수	상	중	하	합계	비고
6차	8	32	35	75	최초 종합 감사
7차	5	29	28	62	6차 47건 수정 확인
8차	6	24	12	42	UX 벤치마킹 포함
9차	4	26	18	48	채팅/커뮤니티 신규 기능 포함
10차	3	17	10	30	소셜/카피 트레이딩 신규 기능

10차에서 총 이슈 건수가 30건으로 감소한 것은 9차 감사 48건 전량 수정(100%)의 성과와, 이번 감사가 신규 소셜 기능에 집
중된 범위 한정 감사임을 반영합니다. Critical 이슈 3건은 모두 카피 트레이딩 관련으로, 금융 로직의 안전성 검증이 핵심입니
다.

13. 종합 평가

13.1 영역별 성숙도 (9차 대비)

항목	9차	10차	변화	비고
인증/인가	4.0/5	4.0/5	—	기존 보안 체계 유지, 커뮤니티 공개 접근 적절
입력 검증	4.5/5	4.0/5	▼-0.5	카피 트레이딩 DTO 검증 미흡
데이터 무결성	3.5/5	3.5/5	—	카피 트레이딩 경합 조건 잔존
소셜 기능 (신규)	—	3.5/5	신규	기본 구현 우수, 옛지 케이스 보완 필요
프론트엔드 UX	3.5/5	4.0/5	▲+0.5	로그인 모달, 공개 접근, 빈 상태 개선

프론트엔드 코드 품질	4.0/5	4.5/5	▲+0.5	이중 주석, 미사용 import 정리, 타입 안정성
i18n	4.0/5	4.0/5	—	49개 키 추가, 일부 누락 잔존
DB 설계	3.5/5	3.5/5	—	신규 테이블 구조 양호, 인덱스/정책 보완 필요
종합	3.8/5	3.9/5	▲+0.1	

13.2 누적 감사 현황

차수	유형	발견	수정	스킵	미수정
1차	신규 감사	36	36	0	0
2차	신규 감사	50	45	4	1
3차	수정 검증	0	—	—	—
4차	신규 감사	79	79	0	0
5차	수정 검증	0	—	—	—
6차	종합 심층 감사	75	47	0	28
7차	종합 정기 감사	62	57	5	0
8차	종합 감사 + UX 벤치마킹	42	42	0	0
9차	종합 정기 감사	48	48	0	0
10차	소셜/UX 기능 감사	30	미수정	0	30
누적		422	354	9	59

13.3 결론

10차 감사는 VirtuEx의 **소셜/커뮤니티 기능 확장**을 중심으로 진행되었습니다. 팔로우 시스템, 활동 피드, 카피 트레이딩, 커뮤니티 공개 설정, 실시간 알림 등 사용자 경험을 크게 확장하는 기능들이 구현되었으며, 전반적인 아키텍처 통합이 우수합니다.

핵심 조치 사항:

1. **카피 트레이딩 안전성** (상 2건): `scaleRatio / stopLossPercent` 입력값 범위 검증, 잔고 경합 조건 해결이 최우선입니다. 금융 로직의 특성상 엣지 케이스가 실질적 자산 오류로 이어질 수 있습니다.
2. **서버 측 검증 강화** (중 4건): 자기 팔로우 방지, 전략 작성 자격 재검증, 카피 트레이더 수 제한 등 프론트엔드 제한만으로 불충분한 항목의 백엔드 검증이 필요합니다.
3. **데이터베이스 최적화** (하 3건): 신규 테이블의 인덱스, 유니크 제약, 데이터 보존 정책을 조기에 설정하여 데이터 증가에 대비해야 합니다.

9차 감사 48건 전량 수정(100%)은 프로젝트의 높은 품질 의식을 보여주며, 종합 성숙도 점수는 3.8에서 **3.9로 소폭 상승**했습니다. 카피 트레이딩의 금융 안전성 이슈 해결 후 4.0 이상 달성이 가능할 것으로 평가됩니다.